웹코드보안
기말 프로젝트

20210765 컴퓨터학과 김예지

목차

- 전자 봉투 시나리오
- 시스템 동작
- 클래스 디자인
- 코드리뷰

#1 - 전자봉투 시나리오

연습생 : 계약서 보낼게요!

연습생이 계약서를 전송할 때

1. 전자서명 생성 : 원본 계약서를 연습생의 Private Key로 전자 서명 생성 후, 파일 저장
2. 전자서명 암호화 : 생성된 전자서명을 Secret Key로 암호화하여 파일 저장
3. 계약서 암호화 : 원본 계약서를 Secret Key로 암호화하여 파일 저장
4. 전자봉투 생성 : Secret Key를 사장님의 Public Key로 암호화하여 파일 저장

#1 - 전자봉투 시나리오

사장님 : 계약서 확인 ~

사장님이 계약서를 검증할 때

1. 전자봉투 복호화: 사장님의 Private Key로 전자봉투를 복호화하여 Secret Key를 획득
2. 전자서명 복호화 : Secret Key로 전자서명을 복호화하여 전자서명 획득
3. 계약서 복호화 : Secret Key로 계약서 복호화하여 계약서 획득
4. 서명 검증 : 해당 서명과 계약서를 비교하여 검증

#2 - 시스템 동작

#3) 코드 리뷰

```java
@NoArgsConstructor
@AllArgsConstructor
@Data
public class Contract implements Serializable {
    private String name;
    private String publicKeyFile;
    private String privateKeyFile;
    private String document;
    private LocalDate startDate;
    private LocalDate endDate;
    private String signFile;
    private String originFile;
}
```

#24) 클래스와 멤버들에 대한 접근성을 최소화 하라

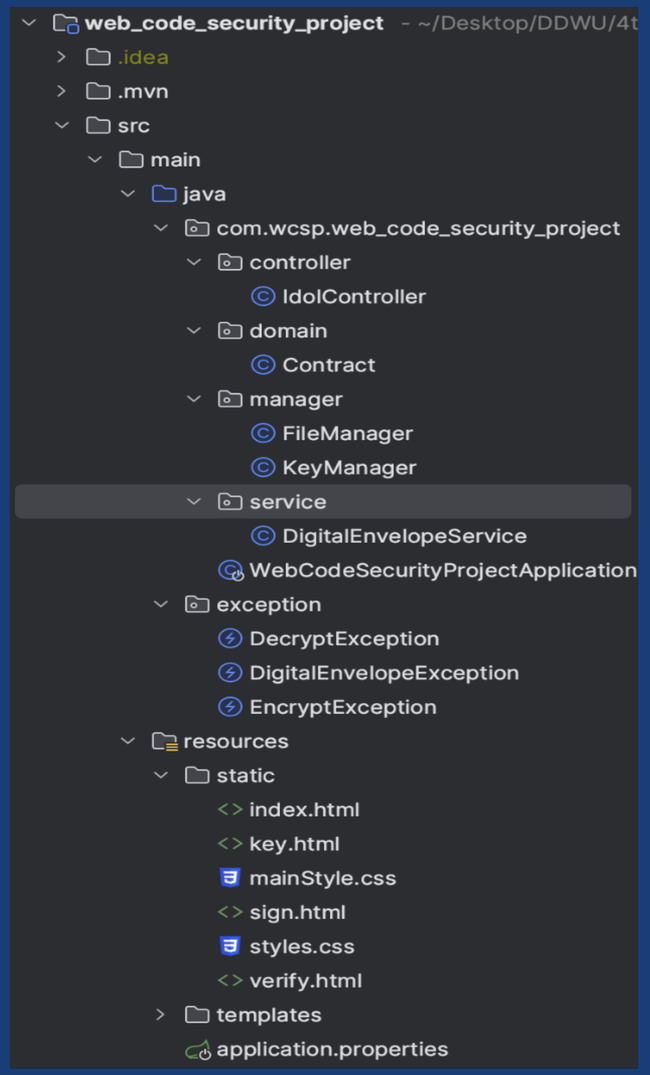
```java
@Getter
public final class Contract implements Serializable {
    private final String name;
    private final String publicKeyFile;
    private final String privateKeyFile;
    private final String document;
    private final LocalDate startDate;
    private final LocalDate endDate;
    private final String signFile;
    private final String originFile;

    no usages  new *
    public Contract(String name, String publicKeyFile, Str
        this.name = name;
        this.publicKeyFile = publicKeyFile;
        this.privateKeyFile = privateKeyFile;
        this.document = document;    You, Moments ago • Unco
        this.startDate = startDate;
        this.endDate = endDate;
        this.signFile = signFile;
        this.originFile = originFile;
    }
}
```

[보안 약점]
- @Data 어노테이션의 getter, setter로 공격자가 값을 임의로 변경할 수 있고, 보안에 관련된 민감한 데이터인 키 파일 이름들이 조회하거나 변경 될 수 있다.

[해결법]
- 클래스는 public final로 더 이상 상속 될 수 없어서 클래스의 불변성을 보장하고, 필드는 private final로 선언하여 초기 계약서를 작성하면 값이 변하지 않아 상태를 유지할 수 있다.
- @Data 어노테이션을 삭제하고 @Getter 어노테이션만 작성하여 setter로 공격자가 값을 변경하지 못 하도록 한다.

#4) 클래스 디자인



controller/IdolController
- 사용자 요청 처리

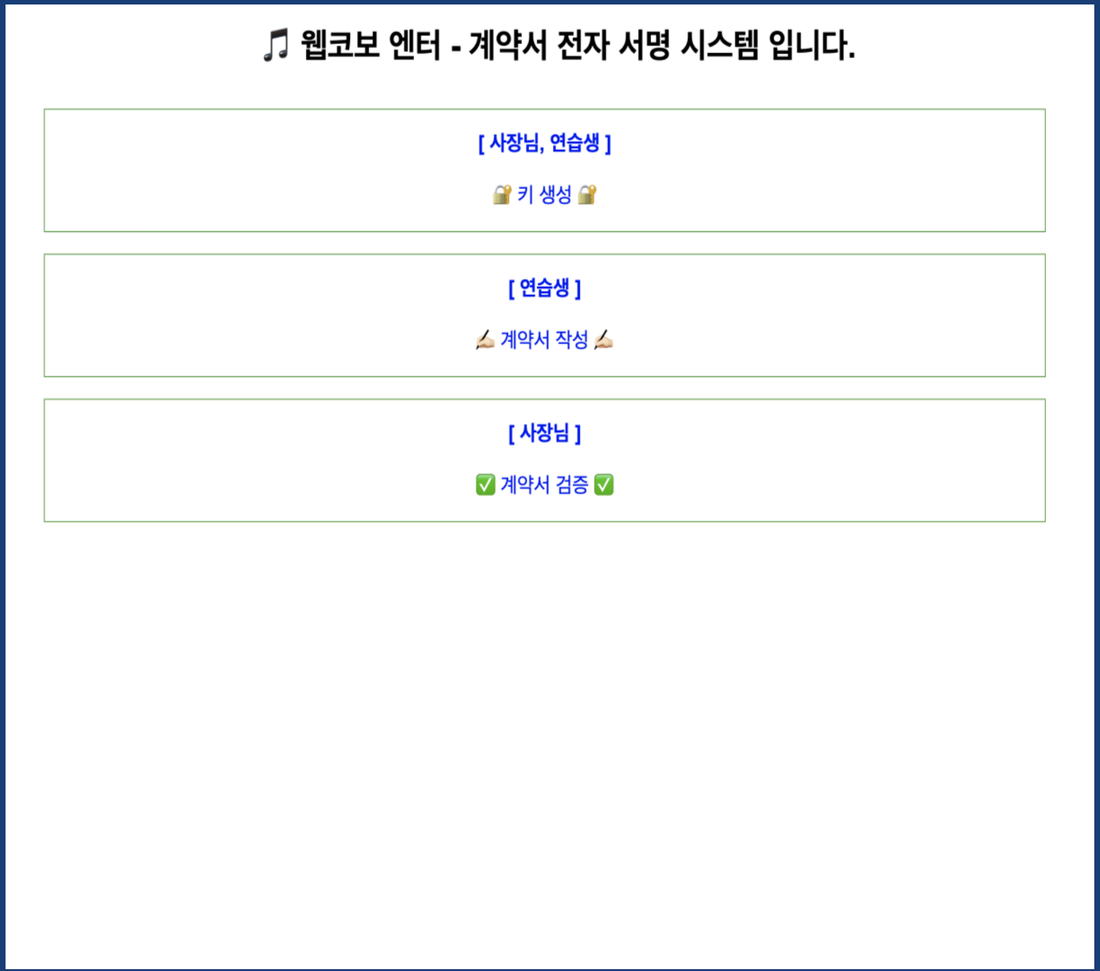
domain/Contract
- 계약서 내용

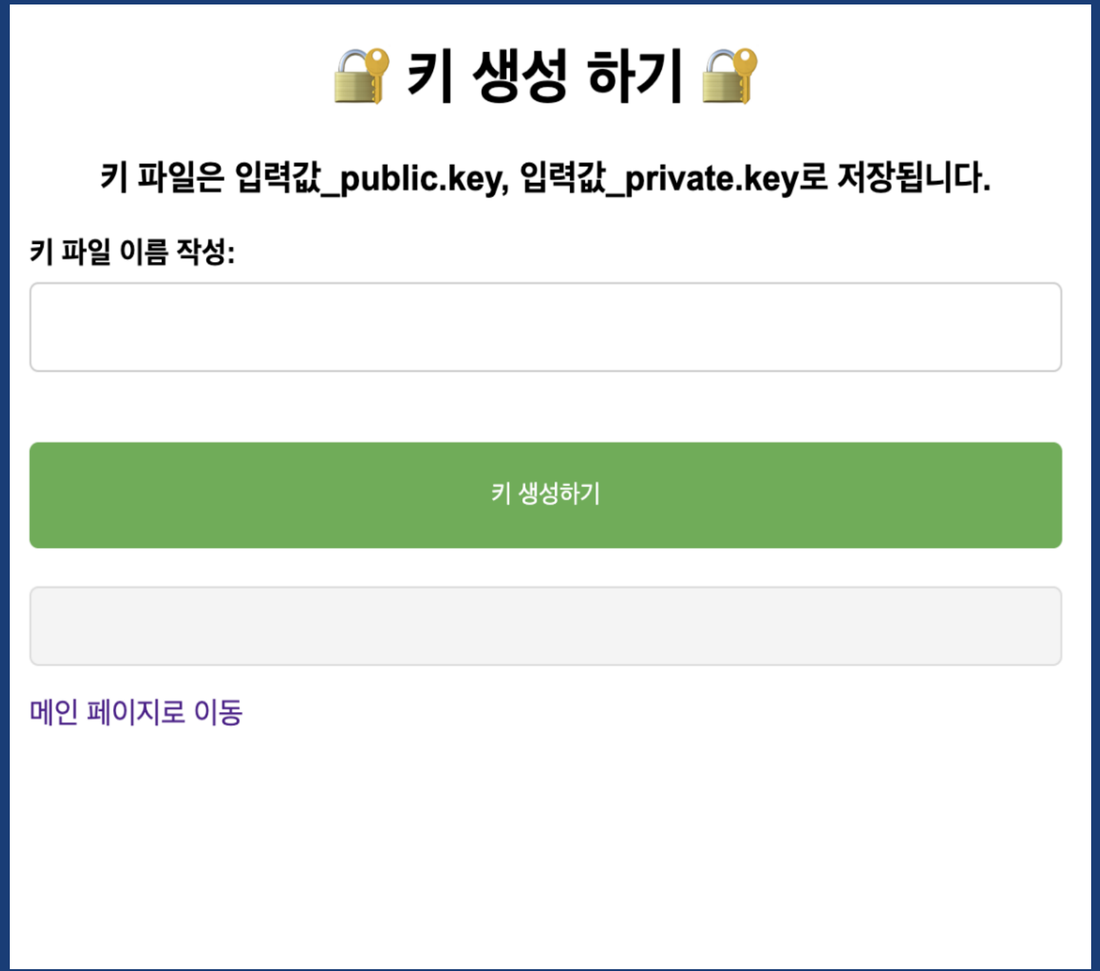
manager
- FileManager : 파일 관리 기능
- KeyManager : 키 관리 기능

service/DigitalEnvelopeService
- 비즈니스 로직 처리
  - 전자서명 생성 및 파일 저장
  - 전자봉투 생성 및 파일 저장
  - 서명 검증

Exception
- 사용자 정의 예외 클래스

#5) UI 설명


🎵 웹코보 엔터 - 계약서 전자 서명 시스템 입니다.
[사장님, 연습생]
🔐 키 생성 🔐
[연습생]
✍️ 계약서 작성 ✍️
[사장님]
✅ 계약서 검증 ✅


🔐 키 생성 하기 🔐
키 파일은 입력값_public.key, 입력값_private.key로 저장됩니다.
키 파일 이름 작성:
키 생성하기
메인 페이지로 이동

#5) UI 설명

아이돌 전자 계약서

이름:

웹코보 엔터의 public key 파일 이름 :

private key 파일 이름 :

내용 :

계약 시작 :

연도. 월. 일.

계약 종료 :

연도. 월. 일.

계약서를 저장할 파일 이름 :

계약서 전송

계약서 검증

연습생의 공개키 이름 :

PrivateKey 파일 이름 :

서명 파일 이름 :

봉투 파일 이름 :

검 파일 이름 :

검증하기 !!!!

메인으로 이동

감사합니다